The Data Protection Failure Inside Every AI Platform

Why No Provider Can Prove Medical, Financial, or Personal Data Was Safe During Processing

---

Basil C. Puglisi, MPA
Human-AI Collaboration Strategist
basilpuglisi.com
March 2026

Public companion to the Verified AI Inference Standards Act (VAISA)

AI Provider Plurality Congressional Package, Document 5

Executive Summary

Every day, hospitals, banks, universities, and federal agencies send sensitive data to AI platforms for processing. The data travels encrypted in transit. It arrives at the platform's inference endpoint. It is decrypted into the platform's processing environment, where it passes through preprocessing layers, enters the model's attention mechanism, flows through transformer layers in GPU VRAM, and produces output tokens that are assembled into a response. From the moment of decryption until the response is re-encrypted for return, the data exists in an environment that the sending organization cannot observe, cannot audit, and cannot verify against any technical standard. This interval is the Invisible Moment, and it occurs billions of times daily across every regulated sector that uses an AI API.

This paper examines the Invisible Moment as a structural gap in data governance and proposes a federal response built on three reinforcing layers.

The first layer is existing law. HIPAA's Security Rule (45 CFR 164.312(b)) requires audit controls for systems containing electronic protected health information. FERPA conditions federal funding on institutional protection of student records processed by third-party systems. Gramm-Leach-Bliley requires financial institutions to ensure the security of customer records handled by service providers. The proposed Protecting AI and Cloud Competition in Defense Act (H.R.3434/S.1775) would, if enacted, require government exclusive rights to data in covered DoD contracts with foundation model providers. Each of these statutes creates a real security and accountability duty that applies when regulated data enters an AI platform. None of them yet specifies a technical mechanism for proving that protection existed at the inference boundary. The duties are on the books. The evidence standard that makes those duties enforceable at the AI layer is not.

The second layer is standards convergence. NIST's February 2026 concept paper on AI agent identity and authorization, the Cloud Security Alliance AI Controls Matrix (243 controls across 18 security domains), the EU AI Act's Annex VII conformity assessment requirements, GDPR Article 25's privacy-by-design obligations, DORA's operational resilience mandates for financial entities, and the UK House of Lords Communications and Digital Committee's March 2026 call for open technical standards have each independently identified the same infrastructure gap. The convergence is not coincidental. Every body examining AI data governance arrives at the same conclusion because the technical gap is structural, not jurisdictional.

The third layer is governance at scale. Enterprise AI has moved beyond single-model assistance into multi-platform orchestration, where a governance decision in healthcare, finance, law, or government may pass through several AI platforms in sequence. Bias can enter at any junction, corrupted systems can influence downstream outputs without detection, and human arbiters reviewing final decisions cannot verify what happened at each intermediate inference step unless attestation exists at every boundary. An open attestation standard is the only form the solution can take without reintroducing the concentration risk that Provider Plurality, the governance principle that no single AI actor should control the decisions that matter most, exists to prevent.

The hardware to address this gap is already deployed. AWS Nitro Enclaves, Azure Confidential Computing (with AMD SEV-SNP and Intel TDX), Google Confidential VMs, and NVIDIA H100 Confidential Computing all provide hardware-isolated Trusted Execution Environments with remote attestation under the IETF RATS architecture (RFC 9334). Remote attestation produces a cryptographic proof, signed by the hardware vendor's attestation key, confirming that specific verified code ran inside specific isolated hardware. A governance system can verify this proof through four deterministic binary checks: signature validation, measurement comparison, nonce verification, and TCB version checking. The checks require no content evaluation and no semantic interpretation.

Based on the public documentation reviewed for this paper as of March 2026, no major commercial LLM API returns this attestation evidence alongside inference responses. Some providers have published early research on confidential inference but describe that work as too early to forecast as a specific product feature. The hardware proves. The platforms don't expose what the hardware proves.

Four structural incentives explain the absence: competitive opacity, where platforms treat infrastructure architecture as proprietary advantage; liability asymmetry, where attestation creates binary evidence that becomes discoverable in regulatory proceedings; absent demand signal, where governance systems capable of consuming attestation are new and the market signal hasn't propagated; and inference economics, where TEE-based processing carries real performance overhead and engineering complexity that competes with model performance investment. These incentives will not self-correct through market forces alone.

The Confidential Processing Extension (CPE) of the GOPEL governance architecture translates this gap into an operational classification. Every governed dispatch to an AI platform falls into exactly one of four profiles, with no dispatch passing through unclassified and defaults failing closed. Profile 1 (Attested Confidential Inference) permits raw regulated data dispatch only when the platform exposes hardware-backed attestation and the governance system verifies it through four binary checks, with two evidence grades distinguishing environment verification from full transaction binding through signed inference receipts. Profile 2 (Minimized External Processing) applies deterministic tokenization to structured regulated identifiers when attestation is unavailable, reducing what is exposed without verifying computation conditions. Profile 3 (Human-Gated Emergency Processing) requires a named human arbiter to explicitly approve time-limited dispatch (72 hours maximum, with mandatory post-use review within 14 days) when neither attestation nor sufficient minimization is available. Profile 0 (Prohibited) is the default state: raw regulated data do not leave the organization's boundary without affirmative qualification for a higher profile.

The Verified AI Inference Standards Act (VAISA), published as Document 5 of the AI Provider Plurality Congressional Package, converts this four-profile classification into federal law through three phases. Phase 1 incorporates attestation API requirements into federal AI procurement under existing OMB M-25-22 acquisition guidance, requiring no new legislation. Phase 2 directs NIST and HHS to publish a Verified Confidential Inference Standard aligned with RFC 9334, including cross-vendor attestation format harmonization, signed inference receipt specifications, coordinated CPU-GPU attestation chain requirements, and proportional compliance pathways for smaller platforms and open-source providers. Phase 3 activates full enforcement with penalty tiers mirroring HIPAA, a private right of action with safe harbors for compliant entities, and a federal floor with state authority preserved above it, contingent on adoption evidence rather than calendar dates alone.

VAISA does not create a new security obligation. Existing law already requires protection of sensitive data during processing. VAISA creates the technical evidence standard that makes those existing obligations enforceable at the AI inference boundary.

This paper also names what attestation does not solve: it proves the processing environment but not the algorithm's behavior; it depends on trust in hardware vendors whose implementations have faced demonstrated side-channel attacks; GPU VRAM protection requires specific hardware not universally deployed; the signed inference receipt is a proposed control that platforms must build; multi-vendor format standardization does not yet exist; and a platform operator who controls the code inside the TEE could deploy software that passes measurement checks but acts against data subjects' interests. Attestation is the foundational layer of the governance evidence stack, not the entire stack. Honest governance names these boundaries rather than overclaiming closure.

The paper documents seven dissents raised during adversarial review by independent AI platforms and explains how each was incorporated, addressed, or dismissed with rationale.

The infrastructure is built. The hardware is deployed. The specifications are published and adversarially reviewed. The platforms need to expose the protections they already possess to the customers, governance systems, and regulators that need to see them.

Methodology and Disclosure

This paper was developed under the HAIA-RECCLIN (Human AI Assistant) framework, which assigns structured roles to AI platforms operating under human authority. The author served as Tier 0 arbiter with final editorial, analytical, and publication authority over all content. AI platforms operating in assigned RECCLIN roles (Researcher, Editor, Coder, Calculator, Liaison, Ideator, Navigator) contributed to drafting, technical verification, legal research, and structural review. The paper was adversarially reviewed under the HAIA-CAIPR (Cross AI Platform Review) protocol, where each platform reviews independently without access to the others' findings. Platforms participating across drafting and review rounds included Claude, ChatGPT, Gemini, Grok, DeepSeek, Kimi, Perplexity, Meta AI, Mistral, and CoPilot. Convergence and dissent were documented, and the Dissent Register at the end of this paper records every substantive disagreement raised during review with the rationale for how each was resolved. Under Checkpoint-Based Governance (CBG v4.7), every editorial decision, structural change, legal correction, and publication approval required explicit human authorization at defined checkpoints. No AI platform operated autonomously. No content was published without Tier 0 arbiter sign-off. The methodology, governance architecture, and review protocols are published at basilpuglisi.com and github.com/basilpuglisi/HAIA.

Existing Law Requires Protection. It Does Not Yet Standardize Proof at the Inference Boundary.

Every time a hospital sends a clinical note to an AI platform for summarization, something happens that no one can verify. The note travels encrypted. It arrives at the platform's inference endpoint. It is decrypted into the platform's processing environment. That environment is opaque. The hospital cannot inspect it, cannot audit it at the moment of inference, and cannot verify against any technical standard whether the data remained protected while the model processed it. A business associate agreement allocates liability after the fact. Nothing verifiable proves what happened during the fact.

This is not a future problem. It is a live compliance exposure created by opaque third-party inference environments handling regulated data.

HIPAA's Security Rule at 45 CFR 164.312(b) requires covered entities and their business associates to implement hardware, software, and procedural mechanisms that record and examine activity in information systems containing electronic protected health information. That requirement applies to AI inference systems that handle ePHI. It requires audit controls and reasonable safeguards, but it does not specify remote attestation or a per-request proof artifact at the inference boundary. As of March 2026, based on the public documentation reviewed for this paper, no major commercial LLM API returns per-request remote attestation evidence alongside inference responses. The audit controls the law requires at the system level have no technical equivalent at the AI inference boundary, and organizations sending regulated data to these platforms have no verifiable evidence of processing conditions to place in their compliance files.

The gap is not confined to healthcare. FERPA conditions federal funding on institutional protection of student education records processed by third-party systems. When a university sends student assessment data to an AI tutoring platform, the same structural gap appears: the platform processes the data in an opaque environment and the institution has no technical mechanism for verifying processing conditions. Gramm-Leach-Bliley requires financial institutions to ensure the security and confidentiality of customer records processed by service providers. When a bank sends transaction data to an AI fraud detection platform, the same gap opens. The Protecting AI and Cloud Competition in Defense Act of 2025 would require, if enacted, that the government maintain exclusive rights to access and use of all government data in covered DoD contracts with foundation model providers. When a federal agency sends procurement data to an AI platform, the same gap is present.

Each of these statutes creates a real security and accountability duty. None of them yet specifies a standard attestation mechanism for proving confidential AI inference at the platform boundary. The duties exist. The technical proof that those duties are met during the most vulnerable moment of processing does not.

The strongest possible opening for a policy argument is one that doesn't ask Congress or regulators to create a new obligation. It asks them to specify the technical evidence standard that makes existing obligations enforceable at the AI inference layer. No new legal theory is required, no speculative harm, and no contested prediction about AI futures. The compliance exposure is present, the control gap is documented, and the legal duties are already on the books.

What Happens Inside the Invisible Moment

Understanding why the gap matters requires understanding what happens technically when governed data enters an AI platform.

A modern LLM inference request follows a specific path. The prompt arrives over TLS (encrypted in transit). At the platform's API gateway, the TLS session terminates and the prompt is decrypted into the platform's processing environment. From that point, the prompt exists in cleartext inside the platform's infrastructure. It passes through preprocessing layers, enters the model's attention mechanism, flows through transformer layers that hold the prompt's tokens in GPU VRAM alongside key-value cache from the attention computation, and produces output tokens that are assembled into a response. The response is encrypted under TLS and returned to the sender.

During every step between TLS termination and response encryption, the prompt data exists in a state that the sending organization cannot observe, cannot verify, and cannot audit. The platform's CPU memory, GPU VRAM, attention key-value cache, speculative decoding buffers, any internal logging or monitoring systems, and the platform operator's administrative access to all of the above are entirely outside the sender's reach.

This is the Invisible Moment. It is not hypothetical. It occurs billions of times daily across every regulated sector that sends sensitive data to an AI API. The gap is not a theoretical concern about what might happen. It is a structural absence of evidence about what is happening right now, at scale, with data that existing law already requires organizations to protect during processing.

The Technical Solution Exists at the Hardware Level

The Invisible Moment is not an unsolvable problem. The hardware to solve it is already deployed.

Trusted Execution Environments (TEEs) create hardware-isolated memory regions where data is decrypted only inside protected silicon that neither the platform operator nor the cloud provider can access. The major cloud providers all offer this capability. AWS Nitro Enclaves provide isolated compute environments with cryptographic attestation. Azure Confidential Computing supports confidential VMs with AMD SEV-SNP and Intel TDX options, with GPU confidentiality available through specific hardware configurations rather than across every Azure confidential offering by default. Google Confidential VMs provide attestation evidence through Google Cloud Attestation. NVIDIA H100 Confidential Computing extends protection to GPU memory, which is where the bulk of transformer inference computation occurs, with modest but non-zero performance overhead that varies by workload, interconnect, and deployment configuration. A complete confidential inference pipeline requires coordinated attestation across both the CPU TEE (where TLS terminates and prompt preprocessing occurs) and the GPU TEE (where transformer computation runs), and the binding between these attestation chains is not yet standardized. The CPU-to-GPU data path, including bounce buffers and interconnect transfers, may traverse non-TEE memory depending on deployment configuration, which means GPU memory protection alone does not guarantee end-to-end confidentiality without coordinated CPU-GPU attestation.

Each of these environments supports remote attestation under the IETF RATS architecture (RFC 9334). Remote attestation produces a cryptographic proof, signed by the hardware vendor's attestation key, confirming that specific verified code ran inside specific isolated hardware at a specific time. The proof contains an enclave measurement (hash of the code

running inside the TEE), the platform's security version number, and a freshness nonce provided by the requesting system. The proof is generated by the hardware, not the platform software. The platform cannot fabricate a valid attestation quote without compromising the silicon itself.

A governance system receiving this proof can verify it through four deterministic binary checks: signature valid or invalid against the hardware vendor's root certificate, enclave measurement matching a pre-approved allowlist or not, freshness nonce matching the issued nonce or not, and TCB version meeting the minimum requirement or not. There is no content evaluation and no semantic interpretation, just binary checks that any deterministic system can perform. The checks themselves are simple, but the enterprise infrastructure to operationalize them at scale is not: organizations must build and maintain measurement allowlists, manage attestation key revocation across hardware vendors, track vendor security bulletins for TCB updates, and handle cross-vendor format differences until the NIST standard defines a unified abstraction layer.

Beyond the environment attestation, a platform can provide a signed inference receipt that binds the specific transaction to the attested environment. The receipt contains the model identifier, the hash of the input prompt, the hash of the output response, the attestation token hash, and a timestamp. Without this receipt, the attestation proves the environment existed but doesn't cryptographically bind the specific transaction to that environment; the connection rests on temporal correlation alone. With the receipt, the binding is complete. The receipt is a proposed platform-level control that goes beyond what current standards define as a standard pass-through artifact, and building it requires engineering investment from the platform. But the underlying attestation evidence is already generated by the hardware.

The infrastructure exists. The hardware is deployed. The cryptographic standards are published. The governance architecture that can consume and verify this evidence is specified and publicly available.

The platforms won't show it.

Based on the public documentation reviewed for this paper as of March 2026, no major commercial LLM API (OpenAI, Anthropic, Google, Meta, Mistral, or other frontier model providers) returns per-request remote attestation evidence alongside inference responses. Some providers, notably Anthropic, have published early research on confidential inference but explicitly describe that work as too early to forecast as a specific product feature. The cloud layer supports attestation. The AI platform APIs built on that cloud layer do not yet expose it to the customers, governance systems, and regulators that need it.

Why Platforms Don't Expose It Today

If the hardware generates the proof and the governance layer can verify it, the obvious question is why no major platform passes it through. Four structural incentives explain the absence.

Competitive opacity. Platforms treat their infrastructure architecture as a competitive advantage. Exposing attestation evidence reveals which hardware, which enclave configuration, and which code image runs the inference. Platforms prefer to make general claims about security rather than provide verifiable proof of specific configurations.

Liability asymmetry. Without attestation, a platform can claim general data protection practices without committing to specific, auditable, verifiable conditions for each inference. Attestation creates a binary record: either the environment was attested at the time of inference

or it wasn't. That binary record becomes evidence in regulatory proceedings. Platforms rationally prefer ambiguity.

Absent demand signal. Until governance infrastructure existed that could consume and verify attestation evidence, there was no technical consumer for it. Enterprises asked platforms "is our data safe?" and accepted policy documents and SOC 2 reports as the answer. Governance orchestrators that can verify hardware attestation deterministically are new, and the demand signal hasn't reached the platforms yet.

Inference economics. TEE-based inference carries real performance and cost overhead. GPU confidential computing mode can reduce throughput, enclave scheduling can reduce utilization, attestation verification adds latency to every request, and multi-region attestation pipelines remain immature. Platforms resist attestation partly because scaling it across distributed inference infrastructure, including multi-tenant GPU clusters, CPU/GPU mixed attestation chains, and heterogeneous hardware pipelines, costs engineering resources that compete directly with model performance investment. The overhead is modest for many workloads but non-zero and dependent on interconnect, bounce buffers, migration, and workload shape, and platforms rationally defer the investment absent a mandate or a market signal strong enough to justify it.

None of these incentives will self-correct through market forces alone. Competitive opacity rewards the status quo, liability asymmetry rewards ambiguity, the demand signal from governance infrastructure needs volume to register, and inference economics make attestation a cost center until the market or regulators make it a revenue requirement.

This is not a new pattern. Every critical infrastructure domain has faced the same structural resistance, and in every case, the governance layer eventually required visibility that the participants would not provide voluntarily.

The Standards Ecosystem Is Converging on the Same Requirement

The compliance argument from existing law is already sufficient to justify action. What makes the case stronger is that every major standards body working on AI data protection has independently identified the same technical gap and moved toward the same class of solution.

NIST's February 2026 concept paper, "Accelerating the Adoption of Software and Artificial Intelligence Agent Identity and Authorization," identifies identity, credentialing, and authorization as core requirements for AI agents operating across APIs and data systems. The initiative explicitly anticipates mechanisms to authenticate AI agents, define and limit their permissions, and ensure they can be properly scoped, monitored, and governed within systems. Attestation is the technical instrument those mechanisms require.

The Cloud Security Alliance AI Controls Matrix, released July 2025, covers 243 controls across 18 security domains including data security, privacy, model robustness, and AI lifecycle management. It positions itself as the foundation for an AI STAR certification and attestation pathway program.

The EU AI Act's Annex VII requires that notified bodies evaluating high-risk AI systems receive full access to training, validation, and testing data through API or other relevant technical means enabling remote access. The first major high-risk compliance date under current law is August 2, 2026. Annex VII addresses conformity assessment access to training and testing data, not runtime inference attestation directly, but the principle of technically accessible evidence for

AI governance extends naturally to the inference boundary, and U.S. enterprises operating globally will face these requirements regardless of domestic law.

The UK House of Lords Communications and Digital Committee, reporting in March 2026, called for a statutory obligation requiring AI developers to adopt open technical standards for data provenance and labeling. The technical standards that committee described extend directly to inference-time data handling.

GDPR Article 25 requires data protection by design and by default, including during processing. DORA is applicable as of January 2025, requiring financial entities to meet digital operational resilience obligations while Member States establish administrative penalties and remedial measures under national law.

When a policy argument can show that existing U.S. law, proposed federal standards, and international regulatory trends all converge on the same infrastructure gap, the argument stops being advocacy and becomes a statement of technical fact with a policy response attached. That is a categorically different kind of document. The convergence is not coincidental. Every body examining AI data governance arrives at the same conclusion because the technical gap is structural, not jurisdictional.

Multi-AI Governance, Bias, Control, and the Case for an Open Standard

The compliance and standards arguments are sufficient to justify the policy ask on their own. The third layer explains why the standard must be open infrastructure rather than a proprietary feature, and why acting now rather than waiting for another mandate is the strategically sound choice.

Enterprise AI has moved beyond single-model assistance into multi-platform orchestration. A governance decision in healthcare, finance, law, or government may now pass through several AI platforms in sequence, with each platform producing outputs that feed the next. Bias can enter at any junction. A corrupted or compromised system can influence downstream outputs without detection. Human arbiters reviewing the final output cannot see what happened at each intermediate inference step unless attestation exists at every boundary.

AI Provider Plurality, the governance principle that no single AI actor should control the decisions that matter most, has a technical corollary at the inference layer. If multiple AI systems process sensitive data across platforms and no attestation standard exists, a single compromised or biased platform can influence an entire governance chain invisibly. The risk that market-level plurality addresses, concentration of AI capability and the corruption or capture of that capability, manifests at the inference boundary. Attestation is what makes plurality operationally meaningful rather than merely contractual.

Governance frameworks that require human checkpoint decisions to rest on verifiable evidence of what AI systems did with the data they processed cannot function without attestation. Without it, every checkpoint rests on the AI provider's self-report. That is not governance. It is trust with a governance label.

The superintelligence risk argument extends this further. The scenarios that most concern AI safety researchers, systems that pursue goals misaligned with human values, systems that manipulate their environment invisibly, systems that deceive operators about their internal states, all depend on a common enabling condition: the system can act in ways that are invisible to oversight at the moment of action. Attestation at the inference boundary does not eliminate

that risk, but it is a necessary layer of the infrastructure that makes oversight technically possible rather than merely aspirational.

This is not speculative. It is the logical extension of the risks that Provider Plurality was designed to address, applied to the technical layer where those risks actually manifest. Governance orchestrators like GOPEL are the instruments. Attestation is the sensory apparatus those instruments require to function. Without it, governance is blind at the exact layer where the most consequential data moves.

This is also why the standard must be open. A proprietary attestation system allows a single platform to offer compliance verification as a competitive moat. Enterprises dependent on that platform for both AI capability and compliance verification cannot switch providers without losing their audit trail. That reintroduces the concentration risk that Provider Plurality exists to prevent, now at the compliance infrastructure layer rather than the capability layer. An open standard, callable through any compliant provider's API and verified against a public specification, serves every governance framework, every regulated sector, and every size of enterprise equally.

The statutory model is HL7 FHIR under the 21st Century Cures Act. Before that mandate, health data interoperability was technically possible and the market was not producing it voluntarily because proprietary data formats created lock-in that benefited large vendors. The mandate created a clear technical requirement, a standards body responsible for the specification, a phased compliance timeline, an enforcement mechanism, and implementation funding. The market followed. The technical complexity of AI inference attestation exceeds the format interoperability challenge that FHIR addressed, because real-time cryptographic verification of heterogeneous hardware environments is a harder engineering problem than data format standardization. But the policy mechanism, a federal standard that converts a technically possible but voluntarily absent capability into a market requirement, is identical. The Cures Act precedent is understood by the same HHS, ONC, and congressional staff who would receive this proposal.

The Four-Profile Classification

The Confidential Processing Extension (CPE), published March 2026 as part of the GOPEL governance architecture, translates the attestation requirement into an operational framework. Every governed dispatch to an AI platform falls into exactly one of four profiles. There is no fifth option. No dispatch passes through unclassified. Defaults fail closed.

Profile 1: Attested Confidential Inference. The platform operates inside a hardware-enforced TEE and exposes remote attestation. The governance system performs four deterministic binary checks before dispatching sensitive data: signature verification against the hardware vendor's root certificate, enclave measurement comparison against a pre-approved allowlist, freshness nonce verification to prevent replay, and TCB version check against the minimum requirement. If all four pass, dispatch proceeds. If any fails, the system pauses and routes to human arbitration.

Profile 1 carries two evidence grades. "VERIFIED ATTESTED ENVIRONMENT" when attestation passes but no signed inference receipt exists; the environment is verified but the binding between attestation and specific transaction rests on temporal correlation. "VERIFIED CONFIDENTIAL PROCESSING" when attestation passes and a signed receipt binds the specific transaction through matching input hashes. The stronger grade confirms both environment and transaction. The weaker grade confirms environment only. Neither overclaims.

In the strongest configuration, the governance system encrypts the prompt to the enclave's public key. The decryption key is released only after the attestation quote verifies against a key management service (AWS KMS with Nitro Enclave conditions, Azure Attestation with policy-driven key release). The platform never receives plaintext outside the enclave boundary.

This is the only profile that permits raw regulated data dispatch without transformation or human override.

Profile 2: Minimized External Processing. Attestation is unavailable. The governance system applies deterministic tokenization to structured regulated identifiers before dispatch: social security numbers, email addresses, phone numbers, account numbers, dates, and other structured PII matched via pre-compiled regex patterns and replaced with consistent placeholder tokens. The token map never leaves the sending organization's custody. The platform processes a minimized representation.

Profile 2 provides partial minimization of structured sensitive data, not comprehensive anonymization. Sensitive information that doesn't match a pattern rule passes through in cleartext. Contextual inference from surrounding text may allow reconstruction of tokenized values. The profile reduces what is exposed. It doesn't verify computation conditions. The report status reads "DISCLOSURE MINIMIZED, CONFIDENTIAL PROCESSING NOT VERIFIED."

Profile 3: Human-Gated Emergency Processing. Neither attestation nor sufficient minimization is available, and a documented operational necessity requires processing. A mandatory pause gate activates. A named human arbiter must review and explicitly approve the dispatch. The approval is logged with the arbiter's identity, the timestamp, the data class involved, the volume of records, and the documented justification. This profile is time-limited (72 hours per authorization, with mandatory post-use review within 14 days) and repeated use without migration toward Profile 1 or 2 constitutes noncompliance.

Profile 0: Prohibited. No attestation, no approved minimization, no human gate approval. Raw regulated data do not leave the organization's boundary for inference at an external platform. This is the default state. Every dispatch begins at Profile 0 and must affirmatively qualify for a higher profile before data are released.

The catch-all enforcement rule maps every dispatch using a matrix of endpoint capability (attested, opaque, experimental) and data sensitivity classification (public, internal, confidential, regulated). Missing capability flags default to opaque. Missing sensitivity labels default to regulated. The defaults fail closed and the human arbiter resolves any ambiguous assignment before data leaves custody.

The Infrastructure Precedent

The objection that mandating attestation visibility is unprecedented doesn't survive contact with history. Every critical infrastructure domain follows the same pattern: the governance layer requires visibility, the participants resist, legislation mandates compliance, and the market adjusts. That pattern has repeated so consistently across sectors that predicting it for AI isn't speculation; it's precedent recognition.

Aircraft transponders were voluntary until they weren't. The FAA mandated Mode C transponders in controlled airspace (14 CFR 91.215) because air traffic control cannot separate aircraft it cannot see, and when ADS-B Out became mandatory in 2020, airlines resisted the cost, but the mandate held and the airspace became safer. The analogy to AI attestation is structural, not functional: transponders broadcast operational content (position and altitude)

while attestation proves environmental conditions (hardware configuration and code measurement) without revealing the content being processed. The governance principle is the same; the technical mechanism is adapted to the domain.

Banks resisted automated reporting requirements under the Bank Secrecy Act, and the cost was real, but the alternative was an unauditable financial system. Suspicious Activity Reports are now mandatory, and the governance infrastructure (FinCEN) requires visibility into transactions the institutions would prefer to keep opaque.

CALEA requires telecommunications carriers to build interception capability into their networks. The carriers resisted, but the mandate held because the governance layer requires visibility regardless of carrier preference.

NERC CIP standards require utilities to maintain auditable records of access to critical cyber assets. Utilities resisted the compliance burden, but the mandate held because the grid requires governance visibility.

AI platforms processing regulated sensitive data are critical infrastructure participants. The governance layer requires visibility into processing conditions. The platforms resist because competitive opacity, liability asymmetry, and inference economics reward the status quo. The precedent across every other critical infrastructure domain is clear.

What the Verified AI Inference Standards Act Does

The Verified AI Inference Standards Act (VAISA), published as Document 5 of the AI Provider Plurality Congressional Package, converts the four-profile classification into federal law. It is the legislative vehicle that closes the gap between what existing law requires and what the AI API market provides.

VAISA rests on three phases, each building on the last.

Phase 1 (immediate, no new legislation required): Agencies begin incorporating attestation API requirements into AI procurement solicitations and contract terms under existing OMB M-25-22 acquisition guidance. Federal procurement can signal demand and build operational evidence, though its reach is limited to platforms serving federal contracts and cannot impose requirements on the broader commercial market. Federal procurement standards have historically become de facto industry baselines (FIPS cryptographic standards being the clearest precedent), so the procurement signal carries influence beyond the federal contract boundary. The procurement hook is self-enforcing: agencies document which platforms provided verifiable evidence of confidential processing and which did not. Regulators and inspectors general can read the audit trail. The market incentive follows.

Phase 2 (target: months 1-12): Congress directs NIST and HHS to publish a Verified Confidential Inference Standard aligned with IETF RATS (RFC 9334) and existing federal data protection mandates. The 12-month timeline is a target, not a guarantee; past NIST standard efforts have taken longer, but the maturity of RFC 9334 and existing confidential computing specifications provides a stronger starting foundation than prior standardization efforts. A core deliverable is cross-vendor attestation format harmonization: Intel TDX, AMD SEV-SNP, and NVIDIA GPU attestation currently use different formats, and the standard must define the abstraction layers that make a unified API possible. The standard should also define the signed inference receipt specification, including transaction binding formats and per-request evidence schemas, so that platforms build to a published standard rather than an undefined legislative requirement. The standard must also address proportional compliance pathways for smaller AI platforms, open-source model providers, and research institutions that may lack access to

H100-class confidential computing hardware, so that VAISA doesn't concentrate the regulated market among large cloud providers. Proportional compliance could include a reduced-burden attestation profile for platforms processing lower-risk regulated data, graduated requirements tied to revenue or processing volume thresholds, and reference architectures that allow smaller providers to achieve Profile 2 compliance through tokenization without requiring the hardware investment that Profile 1 demands. Without these pathways, VAISA risks creating barriers to entry that contradict the AI Provider Plurality principle the Congressional package is built on.

Phase 3 (month 30, contingent on adoption evidence): Full enforcement activates with penalty tiers mirroring HIPAA, a private right of action with statutory damages of $1,000 to $10,000 per violation, safe harbors for compliant entities, and a federal floor with state authority preserved above it. The safe harbors are designed to make compliance achievable: entities that implement a compliant profile classification system, retain signed attestation evidence, and promptly disclose failures receive concrete liability protection. The private right of action supplements regulatory enforcement rather than replacing it, giving individuals a direct stake in the standard's enforcement while the safe harbor ensures that good-faith compliance is rewarded rather than punished. Phase 3 is contingent, not predetermined. If Phase 1 procurement signals and Phase 2 voluntary adoption achieve sufficient market coverage, the legislative mandate becomes a codification of market practice rather than a forcing function. If voluntary adoption remains below critical mass after two to four years of pilot evidence, Phase 3 provides the legislative backstop. The conditions for transition are measured by adoption rates, not by calendar dates alone.

VAISA does not create a new security obligation. Existing law already creates security, accountability, and data protection duties. What these statutes don't yet specify is a standard attestation mechanism for proving confidential AI inference at the platform boundary. VAISA specifies that mechanism. It creates a new evidence requirement that makes existing compliance duties technically enforceable at the AI inference layer.

What This Means for Each Audience

For compliance officers and CISOs: The gap between what HIPAA, FERPA, and GLBA require and what AI APIs provide is an active exposure in every governed workflow that sends sensitive data to a commercial LLM platform. The four-profile classification makes that exposure visible, auditable, and governable. VAISA converts a subjective procurement conversation ("is our data safe?") into a binary audit question: does this platform's API return attestation evidence that the governance system can verify? The answer is binary, auditable, and documented. Enterprise customers can include VAISA-aligned attestation requirements in their procurement specifications today, without waiting for legislation.

For standards bodies: NIST, the CSA, and international regulatory frameworks are already converging on the same technical requirement. VAISA accelerates that convergence into a single federal standard, aligned with RFC 9334 and compatible with EU AI Act requirements, so that the market has one target to implement rather than a fragmented set of customer-specific demands. The coordination failure, where multiple enterprises each demand attestation in different formats, is the stronger argument for federal standardization than market failure alone.

For AI platform providers: The engineering effort is real. Multi-tenant GPU attestation, CPU/GPU mixed attestation chains, and vendor-specific format standardization are significant integration challenges. The mandate forces the investment. Without it, the engineering never happens because competitive opacity and liability asymmetry reward the status quo. With it,

platforms invest because the alternative is exclusion from the regulated market. The first provider to offer attestation-verified inference gains a significant competitive advantage for the next wave of high-value regulated enterprise contracts in financial services, healthcare, government, legal, and insurance. Attestation is a threshold requirement for competing in these markets, not a sole differentiator; enterprises also evaluate capability, latency, price, and ecosystem integration. But every competitor without attestation falls into Profile 0 in every governance audit trail, and that threshold disadvantage compounds as adoption grows.

For Congress: The AI Provider Plurality Congressional Package proposes three actions: fund GOPEL as national infrastructure, mandate API accessibility, and invest in small AI platforms. VAISA provides the specific technical content of the API accessibility mandate. Phase 0 of the Provider Plurality roadmap requires no new appropriation. Phase 1 of VAISA operates under existing procurement authority. Phase 2 uses NIST standard development within existing budget. Phase 3 builds on two to four years of federal operational evidence before the legislative mandate takes effect.

For governance strategists: Attestation is the sensory apparatus that makes governance instruments function. Without it, multi-platform orchestration, human checkpoint authority, cryptographic audit trails, and dissent preservation are all blind at the inference boundary. Attestation doesn't replace governance architecture. It makes governance architecture operationally meaningful by providing the evidence that human arbiters need to make informed decisions about data they can no longer see.

What Attestation Does Not Solve

Honest governance names its limitations in the specification, not in a footnote.

Attestation proves the environment. It does not prove the algorithm's behavior. A platform running verified code in a verified enclave could still produce biased outputs, memorize sensitive data in model weights, or behave in ways that the attestation doesn't capture. Environment verification is foundational but not final.

Attestation depends on trust in hardware vendors. Intel, AMD, ARM, and NVIDIA maintain the TEE implementations and the attestation key infrastructure. Side-channel attacks against enclaves have been demonstrated in research (CacheOut, SGAxe) and require vendor patching. The trust is better founded than contractual assurance (hardware-backed rather than policy-backed) but it is not absolute.

GPU VRAM protection is not universal. CPU-based TEEs (SGX, SEV-SNP) protect main memory but not discrete GPU VRAM on most current architectures. NVIDIA H100 Confidential Computing extends protection to GPU memory, but this requires specific hardware and deployment configuration. Platforms serving inference on older GPU architectures cannot provide the same level of protection.

The signed inference receipt is a proposed control, not a current standard artifact. Building per-transaction binding at scale requires engineering investment that platforms haven't yet made. The attestation quote itself passes through from hardware. The receipt is an additional layer that the market must build.

Multi-vendor attestation format standardization doesn't exist yet. Intel TDX, AMD SEV-SNP, and NVIDIA GPU attestation use different formats. A unified API requires abstraction layers that the NIST standard in Phase 2 must define. Until those layers exist, interoperability is limited.

Attestation verifies that approved code ran in the approved environment. It does not verify that the approved code behaves as the relying party expects. A platform operator who controls the code running inside the TEE could deploy software that passes measurement checks but acts against the data subject's interests, logging prompts, retaining data beyond declared retention periods, or extracting information through side channels within the enclave. The defense against this scenario is independent code audit combined with attestation, not attestation alone. Attestation verifies the environment and code identity; code audit verifies the code's behavior. Neither is sufficient without the other for the highest-assurance deployments.

These limitations do not undermine the case for attestation. They define its boundaries. Attestation is the foundational layer of the governance evidence stack, not the entire stack. It produces the strongest currently available technical evidence that processing conditions met a verified standard. A governance architecture that produces that evidence and honestly names what it cannot verify is categorically stronger than one that produces no evidence at all and relies on contractual assurance to fill the gap.

The Architecture as a Whole

Three layers produce a single clean argument.

Existing law already creates the duties that make attestation necessary. The standards ecosystem is converging on the same technical requirement from multiple directions simultaneously. And the future of safe AI governance at scale, including multi-platform orchestration, bias detection, human authority preservation, and forward-compatible risk management, depends on attestation as open infrastructure rather than proprietary feature.

An open, safety-regulated standard is the only form the solution can take that serves all three layers simultaneously. A proprietary solution cannot satisfy compliance equity across all providers. It cannot serve as a universal standard that emerging frameworks can reference. And it reintroduces the concentration risk that multi-provider governance exists to prevent.

The structural vulnerability worth naming is the leap between the second and third layers. Existing law and emerging standards operate on known, present-tense regulatory logic. The multi-AI governance and superintelligence arguments operate on forward-looking risk logic. Some audiences, particularly legislative staff and compliance officers, will engage confidently with the first two layers and grow skeptical at the third. The solution is not to remove the third layer but to sequence it correctly. The compliance argument leads. The standards convergence validates the direction. The governance risk argument explains why the standard must be open and forward-compatible, not merely compliant with today's requirements. That sequencing makes the argument work for every audience simultaneously.

The infrastructure is built. The hardware is deployed. The specifications are published and adversarially reviewed. What doesn't exist is the federal requirement that AI platforms expose the protections they already possess to the customers, governance systems, and regulators that need to see them.

That is what VAISA creates.

Dissent Register

This paper was adversarially reviewed by seven independent AI platforms under the HAIA-CAIPR (Cross AI Platform Review) protocol. The following dissents were raised across multiple platforms, considered, and either incorporated or dismissed with rationale.

Dissent: The private right of action is a political poison pill that will kill VAISA in committee. Two platforms raised this concern. The dissent is reasonable on political realism grounds: private rights of action face strong industry opposition. The dissent is dismissed for the white paper because VAISA's safe harbor provision makes the private right of action achievable for compliant entities, mirroring the HIPAA enforcement structure that has survived 20 years of political challenge. The political viability of specific enforcement mechanisms belongs in the Congressional strategy discussion, not the public policy document. The white paper describes the mechanism; it does not adjudicate its political survivability.

Dissent: Market-led procurement pressure might make Phase 3 legislation unnecessary. Three platforms raised this possibility. The dissent is reasonable because enterprise procurement power is real and growing. The dissent is addressed rather than dismissed: Phase 3 is explicitly contingent on adoption evidence. If Phases 1 and 2 achieve sufficient market coverage, Phase 3 codifies market practice rather than forcing it. The paper does not present legislation as inevitable regardless of market response.

Dissent: The NIST 12-month timeline for Phase 2 is optimistic given that past NIST standard efforts have taken years. Four platforms raised this concern. The dissent is reasonable based on historical precedent. The dissent is addressed in the text: the 12-month target is framed as a target, not a guarantee, and the paper notes that the maturity of RFC 9334 and existing confidential computing specifications provides a stronger starting foundation than prior efforts. The timeline is aggressive by design; federal AI governance urgency justifies setting a target that creates pressure rather than one that accommodates delay.

Dissent: Homomorphic encryption, zero-knowledge proofs, and federated learning offer alternative paths to confidential processing verification. Two platforms raised this. The dissent is technically valid: these approaches exist as research directions. The dissent is addressed through the four-profile classification: CPE Profile 3 (Cryptographic Experimental) explicitly covers FHE and SMPC workloads on custom research stacks, and the limitations section names attestation as foundational but not final. The paper does not claim attestation is the only possible approach. It claims attestation is the only approach deployable at production scale against standard commercial LLM APIs today, which is factually correct as of March 2026.

Dissent: Sectoral mandates (HHS for healthcare AI first) may be more politically feasible than a cross-industry law. One platform raised this. The dissent is reasonable as a political strategy alternative. The dissent is dismissed because VAISA is cross-sector by design: the same Invisible Moment affects healthcare, financial services, education, defense, and government simultaneously. A sectoral approach would require separate legislative efforts in each domain, each facing its own lobbying resistance, while the underlying technical gap is identical across all sectors. The efficiency argument for a single cross-sector standard that maps to existing sector-specific statutes is stronger than the political path-of-least-resistance argument for fragmented mandates.

Dissent: Performance overhead for TEE-based inference is 10-30%, not "modest," and the paper understates the real cost. One platform cited this range. The dissent is partially valid: overhead varies significantly by workload, and some high-interconnect configurations do see meaningful throughput reduction. The paper addresses this by describing overhead as "non-zero and dependent on interconnect, bounce buffers, migration, and workload shape" without committing to a specific percentage range, because no single range is accurate across all deployment configurations. NVIDIA's own documentation emphasizes workload

dependence. The paper does not claim attestation is free. It claims the cost is manageable and that the regulatory cost of not doing it is higher.

Dissent: VAISA's boundary is unclear for open-source models deployed on customer-controlled infrastructure. One platform raised this. The dissent is valid as a scoping question. VAISA applies to external AI inference services processing regulated data, not to models an organization runs on its own infrastructure under its own operational control. When an organization operates its own hardware with its own attestation capability, the organization is both the data controller and the infrastructure operator, and the Invisible Moment does not arise because the processing environment is not opaque to the data holder. This clarification belongs in the VAISA legislative text (Document 5), not the white paper.

Related Documents

This paper is the public companion to the Verified AI Inference Standards Act (VAISA), published as Document 5 of the AI Provider Plurality Congressional Package:

Document 1: Summary Flyer (elevator pitch for infrastructure proposal)

Document 2: Ethics for Oversight (constitutional and philosophical case)

Document 3: AI Provider Plurality (legislative framework, policy mechanism, funding, appropriations)

Document 4: Methods Addendum (technical specification and operational evidence, v3.1 locked)

Document 5: Verified AI Inference Standards Act (legislative framework for confidential AI attestation)

Supporting technical documents:

- GOPEL Post-Quantum Cryptographic Agility Amendment v1.2 (March 2026, GitHub)
- GOPEL Confidential Processing Extension (CPE) v1.1 (March 2026, GitHub)
- HAIA-RECCLIN Agent Architecture Specification, EU Compliance Version (GitHub)
- Governing AI: When Capability Exceeds Control (Puglisi, 2025, ISBN 9798349677687)

Basil C. Puglisi, MPA

me@basilpuglisi.com | basilpuglisi.com | github.com/basilpuglisi/HAIA

March 2026